

Actividad 01. Análisis y planificación del pentest

1. Objetivo del pentest

- Determinar el nivel de exposición de la aplicación web e identificar los vectores de ataque explotables desde la perspectiva de un atacante externo, evaluando la posibilidad de comprometer la seguridad del sistema.
- Analizar el sistema gestor de base de datos frente a intentos de acceso no autorizados, evaluando el alcance de una posible exfiltración, alteración o pérdida de integridad de la información.
- Cuantificar el impacto técnico y operacional de la explotación de las vulnerabilidades identificadas, determinando el nivel de riesgo real para los activos críticos del sistema.

2. Alcance

La presente evaluación de seguridad se restringe única y exclusivamente a los siguientes componentes lógicos:

- **Capa de Aplicación Web:** Interfaces de usuario, APIs, puntos de entrada (*endpoints*), componentes del lado del servidor y mecanismos de autenticación, autorización y control de sesiones asociados directamente a la aplicación.
- **Capa de Persistencia (Base de Datos):** Motores de bases de datos vinculados a la aplicación, esquemas, procedimientos almacenados y mecanismos de control de acceso del flujo del servicio.

Quedan formalmente excluidos de cualquier prueba intrusiva o de explotación los siguientes activos y vectores:

- **Infraestructura y Servidores:** Hostings físicos o virtuales, hipervisores, servicios del sistema operativo base (SSH, RDP, SMB, etc.) y dispositivos de red subyacentes que no formen parte estricta de la lógica web.
- **Personal y Factor Humano:** Ataques de ingeniería social, *phishing*, *vishing*, suplantación de identidad o cualquier interacción manipulativa dirigida a empleados, colaboradores o contratistas.

- **Terceros y Clientes:** Cuentas, datos o infraestructura perteneciente a usuarios finales, clientes u organizaciones externas que interactúen con el ecosistema.
- **Disponibilidad:** Se prohíben explícitamente ataques de denegación de servicio (DoS/DDoS), pruebas de estrés masivo o cualquier técnica susceptible de degradar la continuidad operativa del servicio.

3. Autorización y condiciones

Permisos requeridos

- **Tipo de Evaluación:** Pruebas de penetración bajo enfoque de **caja gris (Gray-Box Testing)**, orientadas a evaluar la robustez de la lógica de negocio, controles de sesión y mecanismos de autorización desde la perspectiva de un usuario autenticado estándar.
- **Provisión de Credenciales de Prueba:** La organización facilitará credenciales correspondientes a **cuentas de usuario estándar (no privilegiadas)**, creadas exclusivamente con fines de prueba en un entorno controlado.
- **Principio de Mínimo Privilegio:** Queda formalmente estipulado que no se proporcionarán ni emplearán credenciales con privilegios de administrador, superusuario o accesos maestros (*root/admin*) para el inicio de las pruebas. La evaluación medirá la capacidad del auditor para identificar rutas de escalamiento horizontal o vertical de privilegios a partir de un perfil base.

Condiciones acordadas

- **Ventana de Ejecución:** Todas las actividades intrusivas, sondeos activos y fases de explotación simulada se limitarán estrictamente a **horarios de baja demanda operativa**, con el objetivo de no interferir con los flujos regulares de trabajo ni con la experiencia de usuarios concurrentes.
- **Preservación de la Continuidad del Servicio:** Los procedimientos se desarrollarán bajo una política estricta de mitigación de riesgos operativos. En caso de detectarse anomalías, saturación involuntaria de recursos o degradación en los tiempos de respuesta de la aplicación o de la base de datos, las pruebas se pausarán de manera inmediata para coordinar con el equipo de infraestructura.
- **Trazabilidad y Canales de Comunicación:** El equipo auditor mantendrá registro auditable (direcciones IP de origen, marcas de tiempo y *User-Agents* utilizados) y dispondrá de un canal de comunicación de emergencia activo durante toda la ventana de ejecución para reportar contingencias o hallazgos críticos que requieran contención inmediata.

4. Planificación

a. Marco Metodológico (Testing Framework)

La evaluación técnica se basará en la metodología OWASP WSTG (Web Security Testing Guide), alineando la identificación, análisis y verificación de riesgos a las categorías críticas del OWASP Top 10 para Aplicaciones Web.

b. Recopilación de información preventiva

Ejecución de labores de inteligencia de fuentes abiertas (OSINT, por sus siglas en inglés) y reconocimiento pasivo sobre activos vinculados públicamente a la organización.

Fuentes de Información: Consulta y correlación de registros en repositorios públicos, motores de búsqueda avanzados (dorking), certificados TLS/SSL emitidos y metadatos accesibles en internet, con el objetivo de recopilar la mayor información de exposición externa sin realizar interacción intrusiva directa sobre la organización.

c. Recursos necesarios

- Acceso y Conectividad de Red: Enlace estable hacia la interfaz de la aplicación y sus endpoints asociados (garantizando el enrutamiento o habilitación de reglas en listas de control de acceso/WAF para las IPs de auditoría designadas).
- Entorno de Prueba: Disponibilidad y estabilidad del entorno pactado (preproducción/producción), incluyendo el correcto levantamiento del motor de base de datos vinculado.
- Credenciales de Operación: Cuentas de usuario de prueba no privilegiadas activas y configuradas para el acceso funcional según los términos de autorización acordados.

d. Programación de pentest

- Fecha de Inicio / Ventana Operativa: 25 de diciembre de 2026.
- Condición Temporal: Las actividades de escaneo activo y pruebas funcionales se concentrarán dentro de la ventana de baja demanda operativa establecida, minimizando cualquier riesgo residual para los servicios institucionales.

5. Fases del pentest

El proceso de auditoría técnica sobre la plataforma Aurora Market se estructurará en cinco fases secuenciales y controladas.

a. Reconocimiento

Orientado a identificar las entradas de ataque expuesta por Aurora Market. Se ejecutarán técnicas de escaneo de puertos y descubrimiento de servicios habilitados.

Con el objetivo de determinar puntos de entrada activos, firmas de servicios, protocolos de comunicación y posibles puertos desatendidos o expuestos inadvertidamente a la red.

b. Análisis de vulnerabilidades

Exploración técnica en profundidad sobre los servicios e interfaces identificadas. Se combinarán herramientas de inspección automatizada con análisis manual de la lógica de negocio para identificar fallas de diseño, desactualizaciones y configuraciones inseguras.

Se busca catalogar, verificar y clasificar las debilidades del aplicativo web y de la base de datos sin ejecutar acciones destructivas, preparando el terreno para la validación de impacto.

c. Explotación

Se validará la capacidad de seguridad sobre las debilidades confirmadas, utilizando como referencia el estándar OWASP Top 10. Buscando determinar la viabilidad real de comprometer los controles de acceso, la lógica de la aplicación y la persistencia de datos, midiendo la profundidad del acceso que un atacante podría obtener.

d. Post-explotación

Evaluación del alcance (escalamiento de privilegios o acceso a la base de datos) seguida inmediatamente de un procedimiento estricto de sanitización y limpieza.

Se eliminarán cuentas temporales de prueba, archivos residuales, payloads o artefactos generados durante el pentesting, garantizando que el entorno quede en un estado seguro y con su integridad original intacta.

e. Reporte

Consolidación, correlación y documentación técnica de la evidencia recolectada durante el ejercicio. Se entregará un informe formal que incluya un resumen ejecutivo para la toma de decisiones gerenciales y un desglose técnico detallado con recomendaciones de mitigación priorizadas para el equipo de desarrollo e infraestructura.

6. Investigación

La elección de la metodología OWASP Top 10 como pilar de la evaluación sobre Aurora Market es debido a tres razones:

- Especialización en Capa de Aplicación: A diferencia de frameworks orientados a infraestructura de red (como OSSTMM o PTES), OWASP Top 10 centra sus vectores en la arquitectura lógica web y los motores de base de datos interconectados, coincidiendo con la arquitectura de Aurora Market.
- Mitigación del Riesgo en Entornos Privados e Infraestructura Crítica: Al tratarse de una solución para el sector privado, el modelo de amenazas de OWASP aborda de manera directa riesgos con alto impacto financiero y reputacional, tales como exfiltración de registros de clientes, robo de credenciales, alteración de transacciones y compromisos en la cadena de suministro de software.
- Estándar de Cumplimiento y Gobernanza: Facilita la comunicación de riesgos hacia la alta dirección mediante métricas objetivas (CVSS) y proporciona al equipo de desarrollo una guía inmediata de remediación (Secure by Design) fácil de auditar a futuro.